Security & Privacy Disclosure, Final Report

ORF Kids! (at.orf.kids)

Vorkonsens-Werbe-Reichweitenmessung, ein US-Crash-Profiler mit höchster Startpriorität der ganzen App, und ein geteilter extrahierbarer Firebase-Schlüssel, alles auf einer Kinder-App, acht Nachrichten über 74 Tage, keine davon je beantwortet, fünf angebliche Reaktionen, allesamt Zustellfehler

ÖFFENTLICHE OFFENLEGUNG, 17. OKTOBER 2026 — EMBARGO ERREICHT AM 28. SEPTEMBER 2026, KEINE ANTWORT ERHALTEN, KEINE DER FRAGEN BEANTWORTET

Target	Österreichischer Rundfunk (ORF), Würzburggasse 30, 1136 Wien — gesetzlich gebührenfinanzierter öffentlich-rechtliche r Rundfunk, Controller für ORF Kids!
Package	at.orf.kids v1.5.0 (versionCode 271)
Platform Audited	Android, statische Analyse der produktiven APK (19.9 MB, 17.937 Smali-Klassen)
Initial Disclosure (R1)	2026-06-30, an datenschutz@orf.at, kommunikation@orf.at , kids@orf.at, BCC österreichische Datenschutzbehörde (DSB) und EDPS
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	5 (3 Critical, 2 High, 0 Medium)
Correspondence	8 Nachrichten von RFI-IRFOS über 74 Tage (2026-06-30 bis 2026-09-12), 0 inhaltliche Antworten — die 5 weiteren Nachrichten im Thread sind ausnahmslos Zustellfehler-Benach richtigungen (postmaster@orf.at / mailer-daemon), keine Reak-tion von ORF oder einer Behörde
Authorities Notified	Österreichische Datenschutzbehörde (dsb@dsb.gv.at) · Euro-pean Data Protection Supervisor (EDPS, edps@edps.europa.e u)

security@rfi-irfos.com • rfi-irfos.com
ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Scope 5

3 Engagement Summary 5

4 Findings 6

4.1 C1: Hartcodierter Firebase/Google-API-Schlüssel (Projekt orf-push), identisch mit dem Schlüssel der parallelen 19-App-Familien-Offenlegung 6

4.2 C2: INFOnline/IVW-Werbereichweitenmessung mit Vorkonsens-Auto-Init auf einer Kinder-App, ORF-Gesetz §18 untersagt Werbung in Kinderprogrammen . 7

4.3 C3: allowBackup="true" ohne Ausschlussregeln auf einer Kinder-App — App-Daten ungeschützt in Cloud-Backups 7

4.4 H1: GfK-Echtzeit-Video-Tracking protokolliert pro Kind, welches Video gerade läuft 8

4.5 H2: Sentry-NDK-Crashprofiler mit höchster Startpriorität der gesamten App, vor jeder Consent-Entscheidung 8

5 Impact Analysis 9

6 The Complete Chain: Acht Nachrichten, 74 Tage, Null Antworten, Fünf Zustellfehler 9

7 Data Protection — Artikel für Artikel 10

8 Regulatory & Legal Landscape 10

9 Indicators of Compromise 11

10 Disclosure Timeline & Outcome 11

11 Residual Risk & Recommendations 12

Executive Summary

ORF Kids! (at.orf.kids) ist die Kinder-App des Österreichischer Rundfunk (ORF), finanziert durch den verpflichtenden ORF-Beitrag. Eine statische Analyse der produktiven APK v1.5.0 (versionCode 271, 19,9 MB, 17.937 Smali-Klassen) fand drei kritische und zwei hohe Befunde auf einer Anwendung, deren Zielgruppe Kinder sind, und für die das ORF-Gesetz §18 Werbung ausdrücklich untersagt.

C1: ein hartcodierter Firebase/Google-API-Schlüssel für das Projekt 'orf-push' — identisch mit dem Schlüssel, der zugleich im Befund H2 der parallelen 19-App-Familien-Offenlegung dokumentiert ist, ORF Kids! ist Teil desselben geteilten Blast-Radius. C2: INFOnline/IVW-Werbereichweitenmessung läuft über einen ContentProvider, den Android beim Prozessstart instanziiert, vor jeder Consent-Anzeige — auf einer Kinder-App, was sowohl das Werbeverbot nach ORF-Gesetz §18 als auch Art. 8(1)/Art. 13 DSGVO berührt. C3: 'allowBackup="true"' ohne Ausschlussregeln lässt Kinder-Daten ungeschützt in Cloud-Backups sichern.

H1: GfK-Echtzeit-Video-Tracking protokolliert, welches Kind welches Video sieht (145 Klassen im Bitmovin-Player), mit Art.-5(1)(b)/Art.-8-Fragen. H2: ein US-Sentry-NDK-Crash-Profiler startet mit initOrder=2.000.000.000 — vor jeder anderen Komponente der App und vor jeder Consent-Entscheidung —, ohne dokumentierten Art.-44-49-Transfermechanismus. Positiv: eine Didomi-Consent-Plattform ist vorhanden, keine Kamera-/Mikrofon-/Standort-Permission, keine chinesischen SDKs, keine expliziten Werbenetzwerke.

RFI-IRFOS meldete diese Befunde am 30. Juni 2026 an datenschutz@orf.at, kommunikation@orf.at und kids@orf.at, mit der österreichischen Datenschutzbehörde und der EDPS in BCC, und nannte ein Embargo von 28. September 2026. Sieben weitere Nachrichten folgten über insgesamt 74 Tage. Keine einzige erhielt eine inhaltliche Antwort. Die fünf weiteren Nachrichten im Gmail-Thread sind ausnahmslos automatische Zustellfehler-Benachrichtigungen — teils von ORFs eigenem postmaster (für die intern falsche Adresse kommunikation@orf.at), teils von Googles mailer-daemon (für die falschen Behördenadressen post@dsb.gv.at und post@rtr.at, beide Fehler auf RFI-IRFOS' eigener Seite, nicht ORFs). Das Embargo ist nun 19 Tage überfällig.

ID	Severity	Title
C1	CRITICAL	Hartcodierter Firebase/Google-API-Schlüssel (Projekt orf-push), identisch mit dem Schlüssel der parallelen 19-App-Familien-Offenlegung
C2	CRITICAL	INFOnline/IVW-Werbereichweitenmessung mit Vorkonsens-Auto-Init auf einer Kinder-App, ORF-Gesetz §18 untersagt Werbung in Kinderprogrammen
C3	CRITICAL	allowBackup="true" ohne Ausschlussregeln auf einer Kinder-App — App-Daten ungeschützt in Cloud-Backups
H1	HIGH	GfK-Echtzeit-Video-Tracking protokolliert pro Kind, welches Video gerade läuft
H2	HIGH	Sentry-NDK-Crashprofiler mit höchster Startpriorität der gesamten App, vor jeder Consent-Entscheidung

Subject & Scope

Der Österreichische Rundfunk (ORF) ist der gesetzlich gebührenfinanzierte öffentlich-rechtliche Rundfunk Österreichs; jeder Haushalt ist gesetzlich zur Finanzierung verpflichtet. ORF Kids! (at.orf.kids) ist die dedizierte Kinder-App der Familie. Das ORF-Gesetz §18 untersagt Werbung in ORF-Kinderprogrammen ausdrücklich; dieser rechtliche Rahmen bildet den Maßstab, gegen den die Werbereichweitenmessungs-Befunde dieser Offenlegung (C2) zu lesen sind. Die Firebase-Infrastruktur dieser App (‘orf-push‘, siehe C1) ist dieselbe, die auch 14 der 19 Apps der parallelen, gleichzeitig offengelegten ORF-Familien-Disclosure (REF ORF-2026-R1-001) teilen — derselbe Schlüssel, derselbe Blast-Radius, zwei getrennte Fälle.

Engagement Summary

RFI-IRFOS sandte die vollständigen Befunde am 30. Juni 2026 an datenschutz@orf.at, kommunikation@orf.at und kids@orf.at, mit der österreichischen Datenschutzbehörde und der EDPS in BCC, und nannte ein Embargo von 28. September 2026. Diese erste Nachricht erzeugte zwei Zustellfehler: kommunikation@orf.at existiert als Adresse auf ORFs eigenem Mailserver nicht (Antwort von postmaster@orf.at), und post@dsb.gv.at existiert als Adresse bei der österreichischen Datenschutzbehörde nicht (Antwort von Googles mailer-daemon) — beide Fehler betreffen Adressen, die RFI-IRFOS verwendet hatte, nicht ORFs eigene Kommunikationsfähigkeit.

Sieben weitere Nachrichten folgten: 6. Juli (erneuter Zustellfehler für kommunikation@orf.at), 17. Juli (kommunikation@orf.at aus dem Verteiler entfernt, dsb@dsb.gv.at und edps@edps.europa.eu korrekt in CC), 27. Juli, 9. August (mit einer breiten BCC-Liste an ORF-interne Adressen und post@rtr.at, die zu drei weiteren Zustellfehlern führte: kommunikation@orf.at, kundendienst.tirol@orf.at, post@rtr.at), 15. August, 31. August und zuletzt 12. September 2026 — 74 Tage nach der ursprünglichen Offenlegung. Über alle acht inhaltlichen Nachrichten hinweg erhielt RFI-IRFOS keine einzige Antwort von ORF, von kids@orf.at oder von einer Behörde. Jede der fünf weiteren Nachrichten im Thread ist eine automatische Zustellfehler-Benachrichtigung, keine davon stellt eine inhaltliche Reaktion dar. Das Embargo-Datum vom 28. September 2026 ist, zum Zeitpunkt dieser Veröffentlichung, 19 Tage überfällig.

Findings

C1: Hartcodierter Firebase/Google-API-Schlüssel (Projekt orf-push), identisch mit dem Schlüssel der parallelen 19-App-Familien-Offenlegung

CRITICAL, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N, 9.1 — Kinder-App teilt denselben Blast-Radius wie 14 weitere ORF-Apps

```
project_id: orf-push
google_api_key: [REDACTED IN PUBLIC REPORT -- disclosed privately to ORF in R1]
firebase_database_url: orf-push.firebaseio.com
storage_bucket: orf-push.appspot.com
Identisch mit dem Schluessel in Befund H2 der parallelen 19-App-Familien-Offenlegung (
    REF ORF-2026-R1-001)
```

Impact: ORF Kids! bettet denselben extrahierbaren Firebase/Google-API-Schlüssel ein, der auch in 14 der 19 Apps der parallel laufenden ORF-Familien-Offenlegung (REF ORF-2026-R1-001, Befund H2) vorkommt, verknüpft mit dem Projekt ‘orf-push‘. Was in jener Offenlegung ein Familien-weiter Befund ist, bedeutet hier konkret: eine Kinder-App teilt ihre Cloud-Infrastruktur mit dem Rest der Familie, ohne dass App-spezifische Isolation erkennbar ist. Ein ungeschützter Schlüssel dieser Art ermöglicht Kontingent- und Billing-Erschöpfung gegen das zugrunde liegende Google-Cloud-Projekt und eröffnet einen bedingten Pfad zu einem vollständigen Datenbank-Lesezugriff, falls die zugehörigen Firestore/Realtime-Database-Regeln nicht auf authentifizierten, deny-by-default-Zugriff beschränkt sind — hier potenziell auf Daten von Kindern. Die Severity wird gegenüber der rein technischen CVSS-Einstufung in der parallelen Familien-Offenlegung (dort HIGH) hier auf CRITICAL angehoben: RFI-IRFOS blast-radius escalation: raised from HIGH to CRITICAL because the same credential now sits on a children’s app, where Art. 8 GDPR’s heightened protection for minors’ data changes the real-world consequence of any resulting quota exhaustion or database exposure, independent of the underlying CVSS technical scope.

C2: INFOnline/IVW-Werbereichweitenmessung mit Vorkonsens-Auto-Init auf einer Kinder-App, ORF-Gesetz §18 untersagt Werbung in Kinderprogrammen

CRITICAL, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N, 9.2 — strukturelles Vorkonsens-Muster auf gesetzlich werbefreier Kinder-App

```
<provider android:authorities="at.orf.kids.IOLInitProvider" android:enabled="true"
    android:exported="false"
  android:name="de.infonline.lib.iomb.core.IOLInitProvider"/>
endpoints: config.ioam.de/appcfg.php, de.ioam.de/tx.io
Android instanziiert ContentProvider beim Prozessstart, vor der ersten Activity
```

Impact: ORF Kids! registriert, wie der Rest der ORF-Familie, einen INFOnline/IVW-ContentProvider, den Android beim Prozessstart instanziiert — vor jeder Activity, also auch vor jeder Consent-Anzeige. Dieses strukturelle Auto-Init-Muster ist auf jeder ORF-App ein Risikofaktor; auf einer Kinder-App verschärft es sich doppelt: das ORF-Gesetz §18 untersagt Werbung in ORF-Kinderprogrammen ausdrücklich, und Art. 8(1) DSGVO verlangt für die Verarbeitung von Kinderdaten eine besonders sorgfältige Rechtsgrundlage. Dass ein Werbereichweitenmesssystem auf einer App läuft, deren Werbefreiheit gesetzlich festgeschrieben ist, ist unabhängig vom Laufzeitverhalten bereits eine Auffälligkeit, die eine Erklärung verlangt.

C3: allowBackup="true" ohne Ausschlussregeln auf einer Kinder-App — App-Daten ungeschützt in Cloud-Backups

CRITICAL, CVSS v4.0 AV:P/AC:L/AT:N/PR:N/UI:R/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 9.0 — Kinderdaten ohne Backup-Ausschluss, Art. 8 verschärft den sonst gerätegebundenen Befund

Impact: ORF Kids! deklariert 'android:allowBackup="true"' ohne begleitende 'fullBackupContent'-Ausschlussregeln. App-private Daten, einschließlich jeglicher gecachter Sitzungs- oder Nutzungsdaten eines Kindes, werden dadurch ungefiltert in Geräte- und Cloud-Backups (Google One/Drive) übernommen. Für eine Erwachsenen-App wäre dies ein gerätegebundener Härtungsmangel; auf einer Kinder-App verschiebt Art. 8 DSGVO den Maßstab. RFI-IRFOS blast-radius escalation: raised from the LOW/MEDIUM technical severity this same manifest flag carries on an adult-facing app to CRITICAL here, because the data placed into unfiltered backup on this specific app belongs to children, and Art. 8's heightened protection standard makes an otherwise routine hardening gap a real-world child-data-protection failure rather than a generic device-security note.

H1: GfK-Echtzeit-Video-Tracking protokolliert pro Kind, welches Video gerade läuft

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.3 — Server-zu-Server-Echtzeitmessung des Sehverhaltens einzelner Kinder

Impact: ORF Kids! bündelt GfK S2S (145 Klassen innerhalb des Bitmovin-Players) für AGF-artige TV-Reichweitenmessung in Echtzeit. Das Tracking läuft Server-zu-Server und protokolliert, welches Video ein Kind gerade sieht, über eine eigene App-Medien-ID. Diese Granularität — nicht nur Nutzungszeit, sondern konkreter Video-Inhalt pro Sitzung — wirft Fragen nach Zweckbindung (Art. 5(1)(b)) und, bei Kinderdaten, nach der Rechtsgrundlage für eine derart detaillierte Verhaltensmessung (Art. 8) auf.

H2: Sentry-NDK-Crashprofiler mit höchster Startpriorität der gesamten App, vor jeder Consent-Entscheidung

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.2 — initOrder=2.000.000.000, startet vor jeder anderen Komponente

```
<provider android:initOrder="2000000000" ... android:name="io.sentry.android.core.
    SentryInitProvider"/>
Hoechster initOrder-Wert in der gesamten App -- startet vor allen anderen Komponenten
Anbieter: Sentry (USA) -- kein dokumentierter Art.-44-49-Transfermechanismus im Binary
     ersichtlich
```

Impact: ORF Kids! bündelt einen Sentry-NDK-Crash-Profiler, dessen ContentProvider mit ‘ android:initOrder=”2000000000”‘ deklariert ist — dem höchsten in der App vorkommenden Wert, was bedeutet, dass diese Komponente vor jeder anderen, einschließlich jeder Consent-bezogenen Initialisierung, startet. Sentry ist ein US-Unternehmen; ein dokumentierter Art. 4 4-49-Transfermechanismus für diese Übertragung ist aus dem Binary nicht ersichtlich. Die Kombination aus höchster Startpriorität und fehlendem dokumentiertem Transfermechanismus auf einer Kinder-App ist der Grund für die Einstufung als HIGH statt als reine Härtungsnotiz.

Impact Analysis

Drei der fünf Befunde dieser Offenlegung (C1, C2, C3) tragen die Einstufung CRITICAL, weil Art. 8 DSGVO und, bei C2, zusätzlich das ORF-Gesetz §18, denselben technischen Befund auf einer Kinder-App gravierender machen, als er auf einer Erwachsenen-App wäre — bei C1 und C3 handelt es sich jeweils um eine begründete Anhebung gegenüber der rein technischen CVSS-Einstufung, mit der jeweiligen Begründung direkt im Befundtext. H1 und H2 beschreiben jeweils ein granulares Echtzeit-Tracking-Muster, dessen Rechtsgrundlage für Kinderdaten offen bleibt. Positiv festzuhalten: eine Didomi-Consent-Plattform ist vorhanden, es gibt keine Kamera-, Mikrofon- oder Standort-Permission, keine chinesischen SDKs und keine expliziten Werbenetzwerke in der App.

The Complete Chain: Acht Nachrichten, 74 Tage, Null Antworten, Fünf Zustellfehler

Schritt 1 — Offenlegung gesendet: RFI-IRFOS sendet die vollständigen Befunde am 30. Juni 2026 an datenschutz@orf.at, kommunikation@orf.at und kids@orf.at, mit der österreichischen Datenschutzbehörde und der EDPS in BCC, und nennt ein Embargo von 28. September 2026. Zwei Zustellfehler folgen binnen Minuten: kommunikation@orf.at (ORFs eigener postmaster meldet die Adresse als nicht existent) und post@dsb.gv.at (Googles mailer-daemon meldet dieselbe Adresse als nicht existent — ein Fehler auf RFI-IRFOS' Seite, nicht ORFs).

Schritt 2 — Fortgesetzte Fehlversuche: Die Nachfassung vom 6. Juli 2026 erzeugt erneut einen Zustellfehler für kommunikation@orf.at. Ab der Nachfassung vom 17. Juli 2026 wird kommunikation@orf.at aus dem Verteiler entfernt; dsb@dsb.gv.at und edps@edps.europa.eu stehen korrekt in CC. Keine inhaltliche Antwort.

Schritt 3 — Breiter Verteiler, mehr Fehlversuche: Die Nachfassung vom 27. Juli 2026 bleibt unbeantwortet. Die Nachfassung vom 9. August 2026 geht mit einer breiten BCC-Liste an zahlreiche ORF-interne Adressen sowie an post@rtr.at hinaus und erzeugt drei weitere Zustellfehler (kommunikation@orf.at erneut, kundendienst.tirol@orf.at, post@rtr.at — letztere zwei ebenfalls Fehler auf RFI-IRFOS' Seite, nicht ORFs).

Schritt 4 — Letzte Nachfassungen: Die Nachrichten vom 15. August und 31. August 2026 bleiben beide unbeantwortet.

Schritt 5 — Letzte Nachricht: Am 12. September 2026, 74 Tage nach der ursprünglichen Offenlegung, fasst RFI-IRFOS den vollständigen Befundstand ein letztes Mal zusammen. Keine Antwort.

Schritt 6 — Embargo verstreicht unbeantwortet: Das Embargo-Datum 28. September 2026 verstreicht, ohne dass auf eine der acht inhaltlichen Nachrichten reagiert worden wäre.

Schritt 7 — Veröffentlichung: Dieser Report erscheint 19 Tage nach dem Embargo. Von 15 Nachrichten im Thread sind acht inhaltliche RFI-IRFOS-Nachrichten und fünf automatische Zustellfehler-Benachrichtigungen; keine einzige stellt eine inhaltliche Reaktion von ORF, kids@orf.at oder einer Behörde dar.

Data Protection — Artikel für Artikel

Art. 32(1)(b), Art. 5(1)(f), Art. 8 DSGVO — Sicherheit der Verarbeitung, Schutz von Kinderdaten: C1s geteilter Firebase-Schlüssel trifft auf einer Kinder-App einen besonders geschützten Datenbestand.

Art. 8(1), Art. 13 DSGVO — Rechtmäßigkeit bei Kinderdaten, Informationspflichten: C2s Vorkonsens-Auto-Init der INFOnline-Werbereichweitenmessung steht im direkten Konflikt mit dem Werbeverbot nach ORF-Gesetz §18 und mit dem erhöhten Einwilligungsmaßstab für Kinder.

Art. 32(1)(a), Art. 8 DSGVO — Sicherheit der Verarbeitung bei Kinderdaten: C3s ungefiltertes Backup von App-Daten ohne Ausschlussregeln betrifft potenziell Daten von Kindern.

Art. 5(1)(b), Art. 8, Art. 44-49 DSGVO — Zweckbindung, Kinderdaten, internationale Übermittlung: H1s GfK-Echtzeit-Video-Tracking erzeugt ein granulares Verhaltensprofil pro Kind ohne dokumentierte Zweckbindung.

Art. 44-49 DSGVO — Internationale Übermittlung: H2s Sentry-NDK-Profiler mit höchster Startpriorität transferiert mutmaßlich in die USA, ohne dass ein Transfermechanismus im Binary dokumentiert wäre.

Regulatory & Legal Landscape

ORF ist als gesetzlich gebührenfinanzierter öffentlich-rechtlicher Rundfunk Controller für ORF Kids!. Das ORF-Gesetz §18 untersagt Werbung in ORF-Kinderprogrammen; Befund C2 ist unmittelbar an diesem Maßstab zu messen, zusätzlich zu Art. 8 DSGVO. Die österreichische Datenschutzbehörde und die EDPS standen ab der zweiten Nachfassung durchgehend in korrekter CC; eine an post@dsb.gv.at und post@rtr.at adressierte BCC scheiterte jeweils an falschen Adressen auf RFI-IRFOS' Seite, ohne dass dies die Zustellung an die korrekten Adressen (dsb@dsb.gv.at, edps@edps.europa.eu) beeinträchtigt hätte.

Bußgeldrahmen nach DSGVO: Art. 83(5) greift für die Art.-8-Befunde in C1, C2 und C3 sowie für den Art.-8-Aspekt in H1, da es sich um besonders geschützte Verarbeitung von Kinderdaten handelt, bis zu 20.000.000 EUR oder 4% des weltweiten Jahresumsatzes. Art. 83(4) greift ergänzend für den Art.-44-49-Aspekt in H2, bis zu 10.000.000 EUR oder 2% des weltweiten Jahresumsatzes. Vollständiges Schweigen über 74 Tage und acht inhaltliche Nachrichten hinweg, bei zwei Behörden in korrekter CC, ist ein Fakt, den eine Aufsichtsbehörde bei der Bewertung der internen Bearbeitung relevant finden kann.

Indicators of Compromise

Die folgenden Befunde wurden ausschließlich durch statische Analyse der produktiven APK (at.orf.kids v1.5.0) gewonnen. Keine ORF-Server, -Konten oder -Infrastruktur wurden angetestet. Der in Befund C1 referenzierte hartcodierte Credential-Wert ist in diesem öffentlichen Report redigiert; der vollständige Wert wurde ORF im ursprünglichen R1-Schreiben vollständig privat mitgeteilt.

```
C1 -- Firebase orf-push Schluessel, identisch mit Befund H2 der parallelen 19-App-
    Familien-Offenlegung, redigiert in diesem Report
C2 -- INFOnline IOLInitProvider Auto-Init vor Consent, ORF-Gesetz Par.18 Werbeverbot
C3 -- allowBackup=true ohne fullBackupContent-Ausschlussregeln
H1 -- GfK S2S Echtzeit-Video-Tracking (145 Klassen im Bitmovin-Player)
H2 -- Sentry NDK ContentProvider, initOrder=2000000000 (hoechster Wert der App)
```

Disclosure Timeline & Outcome

2026-06-30 Initiale Offenlegung an datenschutz@orf.at, kommunikation@orf.at, kids@orf.at, BCC österreichische DSB und EDPS. Embargo: 2026-09-28. Zwei Zustellfehler binnen Minuten (kommunikation@orf.at, post@dsb.gv.at).

2026-07-06 Nachfassung gesendet. Erneuter Zustellfehler für kommunikation@orf.at. Keine inhaltliche Antwort.

2026-07-17 Nachfassung gesendet, kommunikation@orf.at aus dem Verteiler entfernt, DSB und EDPS in CC. Keine Antwort.

2026-07-27 Nachfassung gesendet. Keine Antwort.

2026-08-09 Nachfassung gesendet, breite BCC-Liste. Drei weitere Zustellfehler (kommunikation@orf.at, kundendienst.tirol@orf.at, post@rtr.at). Keine inhaltliche Antwort.

2026-08-15 Nachfassung gesendet. Keine Antwort.

2026-08-31 Nachfassung gesendet. Keine Antwort.

2026-09-12 Letzte Nachfassung gesendet, 74 Tage seit der ursprünglichen Offenlegung. Keine Antwort.

2026-09-28 Embargo-Datum erreicht und verstrichen, ohne dass auf einen der fünf Befunde reagiert worden wäre.

2026-10-17 Dieser Report veröffentlicht, 19 Tage nach dem Embargo. Korrespondenz-Protokoll: acht inhaltliche RFI-IRFOS-Nachrichten, null inhaltliche Antworten, fünf automatische Zustellfehler-Benachrichtigungen ohne inhaltlichen Wert.

Residual Risk & Recommendations

C1 – Sofortmaßnahme: den geteilten orf-push-Schlüssel auf die produktiven Signaturzertifikate aller betroffenen Apps beschränken, die Firestore/Realtime-Database-Regeln auf den y-by-default/authentifizierten Zugriff prüfen, und den Schlüssel nach Offenlegung rotieren — konsistent mit Befund H2 der parallelen 19-App-Familien-Offenlegung.

C2 – Sofortmaßnahme: mit einer dynamischen Prüfung (Netzwerk-Capture) verifizieren, ob der INFOnline-Auto-Init-Pfad tatsächlich vor einer Consent-Entscheidung überträgt, und, unabhängig vom Ergebnis, die Vereinbarkeit einer Werbereichweitenmessung mit dem Werbeverbot nach ORF-Gesetz §18 auf dieser Kinder-App klären.

C3 – Sofortmaßnahme: ‘fullBackupContent‘-Ausschlussregeln definieren oder ‘allowBackup=”false”‘ setzen.

H1 – Die Rechtsgrundlage und Granularität des GfK-Echtzeit-Video-Trackings auf einer Kinder-App dokumentieren.

H2 – Den initOrder des Sentry-NDK-Profilers auf einen Wert nach der Consent-Initialisierung zurückstufen, und den Art.-44-49-Transfermechanismus für diese US-Übertragung dokumentieren.

Prozedural: RFI-IRFOS bleibt jederzeit offen für eine inhaltliche Antwort zu einem oder mehreren der fünf Befunde; dieser Report wird aktualisiert, sobald eine solche eintrifft.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria Alle Befunde stammen aus statischer Analyse der veröffentlichten Applikation mit öffentlich verfügbaren Werkzeugen. Keine ORF-Server, -Konten oder -Infrastruktur wurden angetestet. Der in Befund C1 referenzierte hartcodierte Credential-Wert ist in diesem öffentlichen Report redigiert; der vollständige Wert wurde ORF im ursprünglichen R1-Schreiben vollständig privat mitgeteilt und bleibt ORF sowie einer Aufsichtsbehörde auf Anfrage verfügbar. Technische Beweise sind unter Chain-of-Custody archiviert. Forschung durchgeführt nach ISO/IEC 29147, der Freiheit der Wissenschaft (Art. 17 StGG) und DSGVO Art. 89. REF ORF-2026-001.